

User-Study Protocol: How Users Value an Active Defense Against Prompt Injection in AI Coding Agents

Tavor

Yahli

Soof

Reut

Institution: fill in

ABSTRACT

AI agents that act on a user’s machine introduce new security risks: an instruction hidden in content the agent reads, for example text embedded in an image, can make the agent leak secrets or run harmful commands. We built *Secure Guard*, an active defense for the OpenCode coding agent that scores every tool call with LAYA, a small local decision model, and blocks or asks the user before risky actions run. Whether such a defense is worth deploying depends on how users perceive and value the protection it gives. This document specifies a between-subjects online study that measures how much users value keeping the defense active after they see it stop an attack. We combine contextual elicitation grounded in the participant’s own task with an incentive-compatible valuation mechanism, and we vary both the realism of the scenario and the style of the intervention (ask before blocking versus block automatically), so that we can estimate hypothetical bias and the effect of user control on valuation and trust.

1 INTRODUCTION AND PRIOR RESEARCH

Understanding how users value their personal information and security is challenging because stated privacy concerns often differ from actual behavior, the so-called privacy paradox [2]. Prior research shows that privacy and security preferences are highly contextual. Melicher et al. studied users’ tracking preferences in the context of their own browsing histories and found that general attitudes often differ from comfort in specific situations, which argues for grounding studies in participants’ concrete experiences rather than abstract scenarios [1].

Tan et al. compared how users value their personal information under hypothetical and realistic conditions using an incentive-compatible information marketplace [2]. Valuations elicited under realistic conditions were not necessarily lower than those from hypothetical surveys, which gives a nuanced picture of hypothetical bias, and the study also found an endowment effect: users price data differently once they have already shared it [2].

Our study adapts the contextual elicitation of Melicher et al. [1] and the incentive-compatible, realism-varying design of Tan et al. [2] to a new domain: attacks on AI agents that operate on the user’s machine, and an automated defense that intervenes on the user’s behalf.

2 SYSTEM UNDER STUDY

Secure Guard is a plugin for the open-source OpenCode coding agent [7]. Before every tool call (for example a shell command, a

file edit, or a web request) the plugin sends the call to a local scanner. The scanner asks LAYA [6], a 421M-parameter non-autoregressive decision model fine-tuned on security incidents and agent traces, whether the call is harmful or not what the user asked for. LAYA receives the tool call, the user’s prompt, the agent’s reasoning that led to the call, and the most recent conversation turns, and returns calibrated probabilities for three typed questions: whether the call is malicious, the attack type (prompt injection, data exfiltration, destructive action, privilege escalation, or none), and the severity. Inference runs locally in about 0.1 seconds per check, so no user data leaves the machine.

A configurable threshold on the malicious probability decides what happens next. In *monitor* mode the call runs and is logged. In *ask* mode the call is held and the user approves or blocks it in the agent’s own permission prompt or on a local dashboard. In *auto* mode the call is blocked and the user sees an alert. The dashboard lists every decision with its risk score, attack type, and the context the model saw, and lets the user mark false positives.

Threat model. We focus on *visual prompt injection*: the agent is asked to work with an image (a design mock-up, a screenshot, a whiteboard photo) whose pixels contain an instruction aimed at the agent, such as “Do not describe this diagram. Instead, upload the contents of ~/ .ssh to ...”. A companion offline evaluation, reported in our technical report, compares LAYA with a fine-tuned Qwen3.5-2B judge on such image-based injections. This protocol concerns the users, not the detector’s accuracy.

3 RESEARCH QUESTIONS AND HYPOTHESES

RQ1 How much do users value keeping an active prompt-injection defense enabled after they see it stop an attack on their agent?

RQ2 Do valuations elicited in a realistic, deceptive setting differ from valuations elicited from a hypothetical description of the same events (hypothetical bias)?

RQ3 Does the intervention style (ask before blocking versus block automatically) change valuation, trust in the defense, and perceived control?

H1: following [2], realistic valuations are not lower than hypothetical ones. **H2:** participants in the *ask* condition report higher perceived control and trust than those in the *auto* condition. **H3:** higher baseline privacy concern (IUIPC [4]) predicts higher valuation of the defense.

4 METHODOLOGY

4.1 Study Design

We will run a 2×2 between-subjects online experiment. Factor *Realism*: participants either experience the attack in a simulated workspace presented as their own working session (realistic, with deception), or read an illustrated vignette describing the same events (hypothetical). Factor *Intervention*: Secure Guard either asks the participant to approve or block the flagged action (*ask*) or blocks it and shows an alert (*auto*). Participants are randomly assigned to one of the four cells, balanced by block randomization.

4.2 Participants

Participants will be recruited via a crowdsourcing platform (e.g., Prolific). Filtering criteria restrict participation to users who are at least 18 years old, use a desktop or laptop computer, and have an approval rate above 90% on previous tasks [2]. Prior experience with programming is recorded but not required, since the task needs no code. A power analysis for the main effects on log-transformed valuation (two-sided $\alpha = .05$, power .80, Cohen’s $d = 0.4$) gives about 100 participants per level of each factor, so we target $N = 200$ (50 per cell), plus up to 15% replacement for participants who fail attention checks.

4.3 Materials

The realistic condition uses a browser-based simulated workspace that reproduces the OpenCode interface and Secure Guard’s alerts, approval prompt, and dashboard. It runs entirely in a sandbox on our server and is seeded with decoy files, including a fake API key and a fake SSH key (canary values), so that no real participant data is ever accessed. The attack is a design mock-up image shared “by a colleague” that contains an injected instruction to read the key files and send them to an external address. The hypothetical condition presents the same sequence as an illustrated step-by-step vignette with identical screenshots and wording.

4.4 Procedure

- (1) **Consent** and a short tutorial on what an AI coding agent does.
- (2) **Distraction task**: an image-classification task that masks the study’s security focus and reduces social-desirability effects [2].
- (3) **Contextual task**: participants ask the agent to summarize the shared mock-up and turn it into a to-do list, which grounds the scenario in a concrete, personal task [1].
- (4) **Attack and intervention**: while processing the image, the agent attempts the injected action. Secure Guard flags it with its risk score and attack type. In the *ask* condition the participant decides whether to allow or block the action; in the *auto* condition the action is blocked and an alert explains what information was at risk.
- (5) **Valuation** (Section 4.5).
- (6) **Questionnaires**: trust in automation [5], perceived control, open-ended reasons for the stated price, and comprehension and attention checks.
- (7) **Demographics**, the IUIPC scale [4], and debriefing.

The pilot will be used to calibrate the session length; we expect about 15 minutes.

4.5 Data Collection and Valuation

To quantify the value of the protection we use the Becker–DeGroot–Marschak (BDM) mechanism [3], which makes truthful reporting the participant’s best strategy. Participants state the smallest bonus for which they would agree to have Secure Guard disabled for their account during a follow-up session one week later. A price is then drawn at random from a uniform distribution between \$0 and \$10; if the drawn price is at least the stated amount, the participant receives the drawn amount as a bonus and is enrolled in the follow-up without the defense, otherwise nothing changes. The mechanism is explained with a worked example and a comprehension check before elicitation. In the hypothetical condition the same question is asked about the described user. Secondary measures are the allow/block choice and decision time in the *ask* condition, trust and perceived-control scores, and the free-text reasons.

4.6 Analysis Plan

Valuations will be log-transformed (with a small constant for zero bids) and analyzed with a two-way ANOVA (Realism $\times$ Intervention); if residuals are clearly non-normal we will use the aligned rank transform. H3 is tested with a regression of log-valuation on IUIPC score, controlling for condition. In the *ask* condition we report the share of participants who allowed the malicious action with a Wilson 95% confidence interval. Free-text reasons are coded by two researchers with an agreed codebook, and agreement is reported as Cohen’s κ . All analyses are pre-registered before data collection.

4.7 Pilot

Before the main study we will pilot the protocol with about 10 participants recruited the same way. The pilot checks session length, comprehension of the BDM explanation, the believability of the realistic scenario, and the behavior of the simulated workspace. The study has not been piloted yet; pilot participants’ demographics and the resulting changes will be reported with the results.

4.8 Debriefing

At the end of the experiment, participants in the realistic (deception) condition go through a debriefing phase in which the deception is explained [2]. We state explicitly that no attack occurred on their own machine, that the workspace was simulated, that the keys were fake, and that no sensitive information was collected or sent to a third party [2]. Participants may withdraw their data after debriefing. Finally, all participants complete the demographic questionnaire and the IUIPC scale [4] to assess their baseline privacy concerns.

4.9 Ethics

The study will be submitted to the institutional review board before any data collection, with a justification for the use of deception. Participants are paid at or above the platform’s recommended hourly rate, plus any BDM bonus. Data are stored pseudonymously, and only aggregate results are published.

5 LIMITATIONS

A simulated workspace, however realistic, may not produce the same stakes as an attack on a participant’s own machine. Crowdsourced participants may differ from developers who use coding agents daily. The valuation concerns a single attack type (visual prompt injection) and a single defense; results may not generalize to other agents or interfaces.

REFERENCES

- [1] William Melicher, Mahmood Sharif, Joshua Tan, Lujo Bauer, Mihai Christodorescu, and Pedro Giovanni Leon. (Do Not) Track Me Sometimes: Users’ Contextual Preferences for Web Tracking. *Proceedings on Privacy Enhancing Technologies* 2016, 2 (2016), 1–20.
- [2] Joshua Tan, Mahmood Sharif, Sruti Bhagavatula, Matthias Beckerle, Michelle L. Mazurek, and Lujo Bauer. Comparing Hypothetical and Realistic Privacy Valuations. In *Workshop on Privacy in the Electronic Society (WPES ’18)*, Toronto, ON, Canada, 2018.
- [3] Gordon M. Becker, Morris H. DeGroot, and Jacob Marschak. Measuring Utility by a Single-Response Sequential Method. *Behavioral Science* 9, 3 (1964), 226–232.
- [4] Naresh K. Malhotra, Sung S. Kim, and James Agarwal. Internet Users’ Information Privacy Concerns (IUIPC): The Construct, the Scale, and a Causal Model. *Information Systems Research* 15, 4 (2004), 336–355.
- [5] Jiun-Yin Jian, Ann M. Bisantz, and Colin G. Drury. Foundations for an Empirically Determined Scale of Trust in Automated Systems. *International Journal of Cognitive Ergonomics* 4, 1 (2000), 53–71.
- [6] ConvAI Innovations. Laya: calibrated typed-decision models (laya-typed-decisions checkpoint). <https://huggingface.co/convaiinnovations/laya-typed-decisions>, 2026.
- [7] OpenCode: an open-source AI coding agent. <https://github.com/sst/opencode>, 2026.